Go-live checklist: the day a pilot confirms

Everything below assumes a customer has said yes and you now need SafeChain running on a real server. Work top to bottom.

The detailed runbook already exists. Do not write another one. This is the short list that sits on top of it:

- `docs/SERVER_SETUP.md` — preparing the host, end to end. Ubuntu base, non-root user, firewall, Docker, directories, the application, TLS, start on boot, scheduled backups, host verification. About 45 minutes. Sizing from your own load tests: **2 vCPU, 4 GB RAM, 50 GB disk** for a 20 to 40 user pilot.
- `docs/GO_LIVE.md` — what changes when it leaves localhost, plus the decisions only you can make.

---

1. Decide before you rent anything: host in Malaysia

SafeChain stores injuries and medical details, which are **sensitive personal data** under the Personal Data Protection Act 2010. If the servers or the backups sit outside Malaysia, section 129 as amended on 1 April 2025 applies: the destination must have substantially similar law or ensure adequate protection, and a Transfer Impact Assessment is expected.

Hosting in Malaysia, backups included, removes that step entirely. It is also a clean answer when a customer's own compliance person asks where their injury records live.

Pick a provider with **encrypted volumes** while you are choosing. Encryption at rest then becomes something you can state truthfully, where today you correctly tell PETRONAS and iG@P that it is not configured.

2. Buy one domain, before the server

The refresh token is an httpOnly cookie marked `SameSite=Strict`, so `app.` **and** `api.` **must sit under the same registrable domain**. Two separate domains break sign-in in a way that is genuinely confusing to debug: the first request succeeds and the session then silently fails to refresh.

Buy the domain first. DNS takes time to propagate and Caddy cannot issue a certificate until the name resolves to your host.

3. Fill the six values that are still blank

`.env.prod` has been rebuilt from `.env.prod.example`, so it now carries all 37 keys and the explanatory comments with them. Your existing values were preserved. These six must be filled before the stack will run correctly:

Key	What to put there
`SAFEOPS_APP_DOMAIN`	`app.yourdomain.my`
`SAFEOPS_API_DOMAIN`	`api.yourdomain.my`, same registrable domain as above
`COOKIE_DOMAIN`	your registrable domain
`ACME_EMAIL`	your email, for the TLS certificate registration
`APP_DB_PASSWORD`	`npm run keygen --prefix api` prints one
A mail transport	either `RESEND_API_KEY` or `SMTP_URL`, not both. `REPORT_EMAIL_FROM` is already set

`APP_PUBLIC_URL` and `CORS_ORIGINS` must also agree with the domains above, or invitation and password-reset links open a page that cannot reach the API.

Set `MFA_SECRET_KEY_B64` **too.** `npm run keygen` prints it. Without it nobody can enable multi-factor sign-in. It is only a warning in the go-live check, but it is a warning you should not be carrying into a customer deployment.

Leave these empty on purpose: `DATABASE_URL` (empty means use the PostgreSQL container that ships with the stack, which is what you want), and `SAFEOPS_API_IMAGE` / `SAFEOPS_WEB_IMAGE` (empty means build on the server). `METRICS_TOKEN` is only needed if you add Prometheus scraping.

Why APP_DB_PASSWORD matters more than it looks

With it set, the service stops running as the Postgres superuser. It can read and write rows and nothing else, and **row-level security keeps each company's rows to that company inside the database itself**. Without it, everything still works, as the superuser, with a warning.

That is the second line of tenant isolation you have already built and tested. It is inert until this one value exists. The go-live check fails on "Database role" if it is missing.

4. Deploy, then run the check

```
docker compose -f docker-compose.prod.yml --env-file .env.prod --profile tls up -d
--build
```

Then:

```
docker compose -f docker-compose.prod.yml --env-file .env.prod exec api node
dist/cli/goLive.js
```

It checks email, demo accounts, backups, database role, multi-factor, the worker, the public address, and the business timezone. It exits non-zero on any failure, so it can gate a deploy script.

Go live with no failures. Every warning should be fixed or decided on purpose.

5. The demo accounts will fail the check, and should

The check fails when a demo account still uses the published password `SafeOpsPlatform2026`. That password appears in `docs/INSTALL.md`, in the seeded demo data, and on the sign-in screen of the server-backed demo.

Remove the demo accounts, or change their passwords, before a customer touches the system. `ALLOW_DEMO_ACCOUNTS` is set to `false` so the check stays a failure rather than a warning. **Do not flip it to silence the message** — that leaves a published password working on a system holding somebody's medical records.

6. Create the customer's workspace

Clear the demonstration data, then create the real workspace and its first administrator with the CLIs in `api/src/cli/`. Do not hand a customer a system with Borneo Industrial Group still in it.

7. The parts no command checks

From `GO_LIVE.md` section 2 onward, and none of it is optional:

- **Where the data lives.** Name the provider and the country, then fill in "Where it is stored" in `PERSONAL_DATA_PROTECTION_NOTICE.md`. That notice cannot be published with the placeholder still in it.
- **Who gets woken when it breaks.** A named person and a number.
- **Where the backups go.** Backups on the same machine as the database are not backups.

- **Man-hours.** Decide whether the customer supplies them, because several figures depend on it.
- **Check it on real phones.** Section 3. A safety officer reports an incident from a phone in a workshop, not from a desk.
- **Check it on a poor connection.** Section 4. Site connectivity in Sarawak is not an office LAN.

What has not been verified

`SERVER_SETUP.md` says so itself and it bears repeating: **none of it has been executed**, because there has never been a server to execute it on. It is written from requirements the application genuinely has, which are verified, but the first real deployment will take longer than 45 minutes and will surface something this list does not mention.

Budget a full day for the first one, not an afternoon.